

	담당	감사실장	비상임감사
결 재	고대현		

2023년 내부통제체계에 의한 자체 정보보안 감사 결과보고

2023. 11.



한국산림복지진흥원
Korea Forest Welfare Institute

목 차

I. 감사실시 개요	1
1. 감사배경 및 목적	1
2. 감사대상 및 감사중점	1
3. 감사실시 과정	2
4. 감사결과 처리	3
II. 감사대상 주요 현황	3
1. 감사 환경분석	3
2. 감사대상 현황	4
III. 감사결과	5
1. 총 평	5
2. 감사결과 총괄	5
3. 감사결과 처분요구	6
4. 내부통제 관련 성과	7
5. 모범사례	7
6. 자체 정보보안감사 유공	10
7. 감사결과 지적사항	10

I. 감사실시 개요

1. 감사배경 및 목적

2023년도 연간 감사계획 및 내부통제체계에 의한 자체 정보보안 감사 계획에 따라 실질적인 리스크 식별과 제도 개선을 바탕으로 진흥원의 내부통제가 활성화되고 지속 발전할 수 있도록 감사를 추진하였다.

코로나19 시기의 신규입사자 급증과 대대적인 조직개편으로 인한 업무 공백이나 착오 등을 최소화하기 위하여 지적보다는 현지시정 및 교육을 통한 “일이 되게 하는 감사”로 추진하였다.

특히 내부통제의 중요성이 강조됨에 따라 감사활동을 통해 본원 주요 부서와 현장에서 내부통제기능이 정상적으로 작동할 수 있도록 지속가능 경영 여건 보장을 감사 목적으로 설정하였다.

2. 감사대상 및 감사중점

감사대상은 본원과 소속기관 임직원(계약직 직원 포함)을 감사 대상으로 설정하였으며, 감사 대상 기간은 2022년 10월부터 2023년 9월까지로 정하였다.

이번 자체 정보보안 감사에서는 진흥원 내부통제체계를 활용하여 2차 방어선인 정보보안팀에서는 정보보호시스템을 통해 임직원의 PC보안 준수와 개인정보 보호 관리실태 등을 원격 감사를 실시하고, 3차 방어선인 청렴윤리 감사실에서는 2차 방어선에서 식별된 문제점에 대해 감사처분 및 업무 개선 등의 감사 처분을 실시하였다.

한편, 현장 감사의 경우 국정원의 정보보안 평가 체크리스트 등을 활용하여 외부 기준에 충족할만한 정보보안 및 개인정보보호가 이뤄지는지를 확인하였다.

정보보안 감사의 중점점검 세부 사항은 아래와 같다.

- ▶ 출처, 유통경로 및 제작자가 불분명한 응용프로그램 설치 유무
- ▶ 인터넷 파일공유·메신저·채팅 등 업무상 불필요한 프로그램 설치 유무
- ▶ 인터넷 PC 문서편집 프로그램 무단 설치, 온라인 문서편집 사이트 이용 유무
- ▶ 음란, 도박, 증권, 가상화폐 거래소, 게임, 웹툰, 인터넷 소셜, 인터넷 우회 접속 등 업무와 무관한 사이트 지속적으로 접속 유무
- ▶ 개인정보 보호조치(암호화, 삭제) 장기간 미실시 유무
- ▶ 개인정보 및 중요 업무자료 무단 반출(저장매체, 이메일 등 전송) 유무
- ▶ 그 외 정보보안 기본지침 '[별표3] 위규자 처리 세부기준'에서 정한 위규사항

3. 감사실시 과정

2023. 10. 17. (화) 자체 정보보안감사 계획을 수립하고, 2023. 10. 26. (목) 정보보안팀에 원격(온라인) 점검 결과 자료를 요청하였다. 원격(온라인) 점검은 2023. 10. 17. (화)부터 11. 17. (금) 까지 1달간 실시하였고, 현장 점검은 원격 점검과 병행하여 2023. 10. 24.(화) 부터 11. 17. (금) 까지 3주간 실시하였다.

2023. 11. 6. (화) 정보보안팀에서는 원격(온라인) 점검 결과자료를 제출 하였으며, 2023. 11. 6. (월)부터 11. 17. (금)까지 자료 분석 및 위규자 면담, 확인서 작성 등의 절차를 진행하였다.

한편, 2023. 11. 2. (목) 소속기관으로 하여금 자체 정보보안감사 수범 사례를 제출토록 요청하였으며, 제출된 4건에 대해 금번 감사 수범사례로 선정하였다.

<2023년 자체 정보보안 감사 실시 개요>

- 감사기간: 총 31일
- 원격점검: '23. 10. 17.(화) ~ 11. 17.(금) / 현장점검: '23. 11. 24.(화) ~ 11. 17.(금)
- 감사범위: '22. 10. 1. ~ '23. 9. 30.까지 임직원의 정보보안 준수 및 개인정보보호 실태
- 감사인원: 청렴윤리감사실장 외 7명(감사담당자 1명, 감사지원 6명)
- 감사대상: 본원 및 소속기관 임직원

4. 감사결과 처리

감사원 「공공감사기준」 제28조에 따른 감사보고서에 필요한 사항을 포함하였고, 제출된 원격 점검 결과를 본원 정보보안 분야 내부통제 기능인 정보보안팀과 의견을 나누었다. 이를 통해 지적·개선 사항을 검토하고, 비상임감사의 보고를 거쳐 2023. 11. 30.에 자체 정보보안 감사 결과를 최종 확정하였다.

Ⅱ. 감사대상 주요 현황

1. 감사 환경 분석

1) 대외 환경

진흥원은 위탁집행형 준정부기관으로서 정부의 정보보안 및 개인정보 보호 관련 제규정 등을 준수의무를 가지며, 국가정보원에서 실시하는 정보보안 평가 등을 통해 준수 정도를 평가받는다.

2) 대내 여건

진흥원은 산림복지시설(소속기관)의 운영을 통해 국민에게 산림복지 서비스를 제공하고 있는데, 효과적인 산림복지프로그램 제공 및 안전보장을 위한 여행자 보험 가입 등의 사유로 방문 고객의 동의하에 개인정보를 수집·관리하고 있다. 진흥원은 19개의 소속기관을 운영하고 있는데 전국에 산재해 있어 직원이 정보보안을 준수하고 있는지에 대해 현장 관리가 어려워 내부통제가 곤란한 여건이다.

한편, 진흥원은 '16년 개원 후 운영시설의 지속 확대로 3년 미만의 신규직원이 전국의 소속기관에 배치되었으며, 이중 30대 미만 직원의 비율이 70% 수준으로 젊은 조직이다.

3) 시사점

진흥원은 준정부기관에 걸맞는 수준의 정보보안인프라 구축하여 전사적 정보보안시스템을 마련해야 하고, 기관 특성상 다수의 개인정보를 수집·관리 하기에 직원의 정보보안 및 개인정보 보호 의식도 지속 제고하여야 한다.

한편, 업무 지적이 아닌 현지 교육·업무 개선을 통해 업무 중 시행 착오를 최소화하고 위반 사항을 사전 예방하는 감사가 필요한 실정이다.

4) 감사 목적

이러한 시사점을 반영하여 자체 정보보안 감사를 통해 정보보안 관리 체계를 마련하고 효율적인 정보보안이 이루어질 수 있도록 규정 및 제도를 개선하며, 직원의 정보보안 수준 및 개인정보 보호 인식을 향상시키고 끝으로 대외 정보보안 정책 기조에 동참하여진흥원의 지속가능 경영 여건을 보장하는데 감사 목적이 있다.

2. 감사대상 현황

진흥원은 치유원(1기관), 숲체원(7기관), 치유의숲(9기관), 연구개발센터(1기관), 추모원(1기관)으로 편성되어 있고, 본원을 포함한다.

구분	분류		본원	치유원 (1)	연구개발센터 (1)	숲체원(7)							치유의숲(9)									추모원 (1)	유동원	총 합계
						형성	칠곡	장성	청도	대전	춘천	나주	양평	대관령	김천	제천	예산	대운산	곡성	화순	고창	부안	하남	유정원
인원 수(명)	정원	113	78	20	38	26	32	20	26	26	25	5	5	4	4	4	5	4	3	3	3	0	9	453
	현원	119	69	19	32	24	29	19	26	25	23	4	4	4	3	4	3	3	2	3	2	5	0	422

Ⅲ. 감사결과

1. 총 평

진흥원은 2020년 10월부터 부패리스크를 시스템적으로 진단·예방하는 부패방지경영시스템(ISO37001)을 3년간 연속 인증 획득하였고, 2023년 11월에 규범준수경영시스템(ISO37301) 인증을 취득하여 내부통제 사각지대를 식별하고 개선점을 도출하는 등 경영관리와 사업 전반에 대한 리스크 예방에 노력하였다.

연간 감사 목표에 따른 추진전략 및 실행과제를 이행하고자 대내외 환경 분석 기반의 2023년 자체 정보보안 감사 추진 방향을 설정하고, 진흥원 임직원에 대한 자체 정보보안 감사를 실시하였다. 그 결과, 고의·중과실 사항은 없었고, 업무용PC로 업무와 무관한 비인가 사이트 접속 방지 등 2건의 결함 사항을 식별하여 개선 조치 및 현지시정을 실시하였다.

또한, 수감기관이 정보보안 및 개인정보 보호 노력을 적극적으로 추진하여 우수성과를 창출한 모범사례 4건을 발굴하였다.

본 자체 정보보안 감사를 통해 드러난 문제점과 개선사항은 적절한 조치가 이루어지도록 지속 관리하고, 모범사례와 함께 전 부서에 전파·공유하여 향후 업무추진에 참고하도록 할 예정이다.

2. 감사결과 총괄

지적사항 1건(개선1건), 현지처분 1건, 모범사례 4건을 확인하여 감사 조치하였음

(단위: 건, 천원, 명)

처분요구			행정상조치 (기관)					재정상조치 (금액)		신분상조치 (인원)		현지 처분	적극 행정 면책	모범 사례
건수	금액	인원	주의 경고	시정	개선	권고	통보	시정 (금액)	지급	징계 문책	주의 경고			
1	-	-	-	-	1	-	-	-	-	-	-	1	-	4

3. 감사결과 처분요구

(단위: 건, 천원, 명)

구분	연번	지적사항	관계기관	처분요구		
				행정상 (기관)	재정상 (천원)	신분상 (명)
지적 사례	1	업무용PC로 업무와 무관한 비인가 사이트 접속 차단	한 국 산 립 복 지 진 흥 원	개 선 (1)	-	-
	2	업무 중 업무용PC로 업무와 무관한 비인가 사이트 접속	X X 팀	-	-	현자사정 (1)
모범 사례	3	기관 특화형 체계적·주기적 정보보안 관리로 직원의 보안의식 강화	국 립 대 전 숲 체 원	-	-	모범사례
	4	자체 보안점검 실시로 정보보안 지적사례 Zero	국 립 칠 곡 숲 체 원	-	-	모범사례
	5	정보보안 취약시기 내부직원 의식개선을 통한 보안 강화	국 립 장 성 숲 체 원	-	-	모범사례
	6	정보보안 모니터링 인프라 기반 정보보안 강화	국 립 산 립 치 유 원		-	모범사례

4. 내부통제 관련 성과

2023년 자체 정보보안 감사에서는 감사원에서 요구하는 수준의 내부통제 활동이 잘 이루어지고 있는지에 주안점을 두고 감사를 추진하였다. 특히, 정보보안 분야의 3차 방어선을 구축하여 1차 방어선(현업부서)에서는 정보보안·개인정보 보호 매뉴얼을 통해 자율 통제를 하였고, 2차 방어선(정보보안 총괄부서)에서는 진흥원의 정보보호시스템을 통해 임직원의 PC보안 준수 및 개인정보 보호 관리실태 등을 원격 점검을 실시하였으며, 3차 방어선(감사 부서)에서는 2차 방어선(정보보안 총괄부서)에서 식별된 문제점에 대해 현지시정 등 조치를 하였으며, 1차 방어선(현업부서)의 정보보안 준수 및 개인정보 보호 노력을 점검하고 우수사례를 선정하였다.

이에 다음과 같이 내부통제시스템이 정상적으로 작동하는데 기여하는 대표적인 성과를 달성하였다.

- ① 일부 직원은 업무용PC를 통해 업무와 무관한 비인가 사이트(투자정보, 웹툰 등 불법 유통)에 접속한 사실을 확인하였기에 해당 사이트를 차단 조치하고, 이와 같은 상황을 전직원에게 공유하여 재발하지 않도록 개선 완료
- ② XX팀 AA는 업무 중 업무용PC를 통해 업무와 무관한 비인가 사이트(가상화폐거래소)에 접속한 사실을 확인하여 해당 직원을 현지시정하고 재발 방지 약속

5. 모범사례

가. 기관 특화형 체계적·주기적 정보보안 관리로 직원의 보안의식 강화

국립대전숲체원은 '22년도 자체 정보보안평가에서 3등 달성하였고 '23년 전보·육아휴직 복귀자가 전체 인원에 42%를 차지하기에 정보보안 개선 노력과 이해도 제고가 필요한 실정이다.

대전숲체원 고객지원팀 김지원 주임은 이와 같은 상황을 개선하고자, '기관 실정에 맞는 체계적·주기적인 정보보안 관리로 직원의 보안의식 강화'라는 목표로 수립하였다.

① 자체 정보보안 점검을 실시하고 월 2회 주기적 정보보안 모니터링을 실시하였다. ② 전년도 미흡사항 및 보안필요성 등을 반영한 맞춤형 교육자료 작성하였다. 특히, 전달력과 이해도를 향상시키기 위해 담당자가 직접 동영상 교재를 촬영·제작하여 전직원에게 배포하였고 동영상플랫폼에 업로드하여 언제든지 반복적으로 교육을 들을 수 있는 인프라를 구축하였다. ③ 마지막으로 직원의 동기부여 제고를 위해 자체 정보보안 문제풀이를 실시하고 1등에게 상품을 지급하였다.

이에 '23년도 자체 정보보안감사 현장점검 평가 결과 만점 달성하였고, 본원 정보보안팀의 사이버 보안 진단의 날(월1회)에서 대전숲체원 전직원 개인정보 암호화율 100%을 달성에 기여하였다.

나. 자체 보안점검 실시로 정보보안 지적사례 Zero!

칠곡숲체원 고객지원팀 전호현 주임은 칠곡숲체원의 정보보안을 강화하기 위해 자발적인 정보보안 점검을 실시하여 위규사항이 발생하지 않도록 사전 조치하였다. 먼저 업무분장을 통해 정보보안 담당자를 지정하고 자체 보안점검계획을 수립하여 정보보안 미흡사항을 점검하였다.

이를 통해 휴대용 저장매체(USB) 라벨 누락, 프린터복합기 보안 취약의 미흡사항을 도출하여 신속히 조치하였다. 또한, 칠곡숲체원 직원의 정보보안 의식을 개선하기 위해 자체 교육과 함께 해킹메일 대응 훈련, 보안시험 문제풀이 등 직원이 직접 참여할 수 있는 훈련을 병행하였다. 이를 통해 자체 정보보안 감사에서 지적사례가 0건인 성과를 창출하였다.

다. 정보보안 취약시기 내부직원 의식개선을 통한 보안 강화

장성숲체원은 자체 복무·정보보안 강화 계획을 수립하여 정기 점검을 실시하고 있으나, 정보보안 강화를 위한 직원의 자발적인 참여와 역량 강화가 필요한 상황이다.

장성숲체원 고객지원팀 김동근 주임은 자체 개인정보보호·정보보안 교육 4회 실시하고, 정보보안 취약 시기*에 보안실태점검표를 통한 내부직원 정보보안 점검 실시 하였으며, 점검 결과에 따른 단계별 조치를 실시하였고, 장성숲체원 직원 2명을 적발하여 구두주의 및 패널티(비선호일 당직지정) 1회 부여하는 조치를 하였다.

이를 통해 내부직원 개인정보보호 및 정보보안 교육 이수를 통한 전문 지식 함양과 자체 보안관리 점검을 통한 복무 및 정보보안 의식 개선 및 안전사고 예방에 기여하였다.

* 취약시기: 연말연시, 대통령 해외 순방에 따른 국정공백, 하계 휴가철·추석 명절 등

라. 모니터링 인프라 기반 정보보안 강화

국립산림치유원은 고객의 요청으로 무선인터넷(7개소)를 설치하여 운영중인데 무선인터넷은 보안에 취약하다는 단점이 있어 조치가 필요하고 보유 장비가 다수이고 노후하여 시스템 오류가 증가하고 있어 개선이 필요한 실정이다.

국립산림치유원 안전관리팀 신민호 주임은 문제해결을 위해 먼저 산림치유원 정보보안 인프라를 통해 네트워크 접속 기록(Log 분석), 보안설정 및 비인가장비 접속 시도 여부 등을 수시 점검하였다. 또한, 주기적인 사무공간 보안 및 네트워크 사용현황을 점검하여 랜섬웨어 의심증상을 조기에 발견하고 차단함으로써 정보보안 강화에 노력하였다. 한편, 미사용 전산기기 점검을 통해 불필요하게 보유중인 개인정보를 선제적으로 삭제 조치하였다. 이를 통해 네트워크·보안 인프라에 대한 보안 침해, 개인정보 누출 등 보안 사고 0건으로 사전 예방하였다.

6. 자체 정보보안 감사 유공

한국산림복지진흥원 경영기획본부 정보보안팀은 2023년 한국산림복지진흥원 자체 정보보안감사에서 정보보안시스템을 활용하여 정보보안 점검을 실시하였으며, 정보보안 및 개인정보보호 체크리스트를 작성하여 직원이 정보보안을 준수할 수 있도록 업무를 추진하여 보안사고 0건으로 지속 유지·관리하였음으로 그 공로를 감안하여 감사 유공 대상으로 선정하여 진흥원장 상장을 추천하였다.

7. 감사결과 지적사항

① 업무용PC로 업무와 무관한 비인가 사이트 접속 방지 【개선】

- 진흥원 「정보보안 기본지침」 제22조에 따르면, PC 등 단말기 사용자는 사용 PC 등 단말기 사용과 관련한 일체의 보안 책임을 가지며 보안

관리를 위해 업무와 무관한 사이트 접근금지를 준수해야 함.

- 그런데, 일부 직원이 업무용PC를 통해 업무와 무관한 비인가 사이트 (웹툰 등 불법 유통, 투자정보)에 접속한 기록을 확인하였기에 해당 사이트를 차단하고 조치 결과를 전직원에게 공유하여 재발하지 않도록 업무 개선 함

➔ 임직원이 업무용PC를 통해 업무와 무관한 비인가 사이트에 접속하지 않도록 사이트 차단 완료 (개선 완료)

② 업무 중 업무용PC로 업무와 무관한 비인가 사이트 접속 【개선】

- 진흥원 「정보보안 기본지침」 제22조에 따르면, PC 등 단말기 사용자는 사용 PC 등 단말기 사용과 관련한 일체의 보안 책임을 가지며 보안 관리를 위해 업무와 무관한 사이트 접근금지를 준수해야 함.
- XX팀 AA는 업무 중 업무용PC로 업무와 무관한 비인가 사이트(가상화폐 거래소)를 접속한 기록을 확인하였기에 감사실장 구두경고 하고 재발 방지 약속하여 현지시정 함.

➔ XX팀 AA는 업무 중 업무용PC로 업무와 무관한 비인가 사이트 접속을 일체 삼가도록 함(현지시정)